



QA · Security · UAT Report

Nemesis AI · "Remediation Re-test" cycle

Date: 2026-06-09 · **Scope:** the Remediation Re-test feature + the audit-remediation waves shipped this cycle.

Verdict: ✓ **SHIP.** All defects found were remediated before moving forward · 146/146 tests pass on first run · UAT signed off.

100%
QA pass rate on first run (146/146 tests, tsc clean)

4 / 4
new defects this cycle — found & fixed before QA hand-off (0 escaped)

78% / 72%
coverage of the changed security modules (urlValidation / reporting) — floor met

6 / 6
UAT acceptance criteria passed → signed off

1 · Automated test coverage of new/changed code (floor 70–80%)

Added **4 test files / 27 tests** on the highest-risk changed modules.

Changed module	What changed	Stmts	Branch	Funcs	Floor
lib/urlValidation.ts	H-02 fail-closed SSRF gate + metadata guard	78%	79%	89%	✓
services/claude/reporting.ts	C-02 TC-NNN prompt-id remap	72%	45%	84%	✓
lib/json.ts → getByPath	M-09 non-object guard	function fully covered			✓
lib/branding.ts → sniffImageMime	L-03 magic-byte check	function fully covered			✓

Gap (tracked): the DB-heavy `reverifyRun` controller + the `skipSuiteGeneration` executor path are covered by **e2e/UAT**, not unit tests; several controller-level audit fixes (auth/MFA/webhook) lack unit tests. → Backlog: a controller integration-test harness (next cycle).

2 · QA pass rate on first run

`tsc` clean (server + client). **vitest: 146 / 146 passed (35 files) — 100% first-run pass.** Client build green.

3 · Security findings by severity & % remediated

Source	Crit	High	Med	Low	Total	Remediated before moving forward
Original audit (<code>nemesis-vapt/</code>)	2	6	12	11	31*	25 fixed; 6 deferred w/ rationale (incl. M-06 closed on prod)
Fresh-eyes review (this cycle)	0	0	1	2	3	3 / 3 fixed
Found while writing tests	0	0	1	0	1	1 / 1 fixed (IPv6-bracket metadata bypass)

*3 Info excluded. **This cycle's new defects: 4 found → 4 remediated = 100% before ship.** The 6 deferred audit items are Medium/Low or defense-in-depth (e.g. H-05 needs a tested auth-flow rollout) and sit in the next-cycle backlog.
Live re-checks (local, post-rebuild): malformed JSON → **400** (L-11) · `/agents` unauth → **401** · admin login → **200**.

4 · UAT sign-off — Remediation Re-test (vs acceptance criteria)

Acceptance criterion	Result	Evidence
Endpoint reachable + permission-gated	PASS	unauth <code>POST /reverify</code> → 401
Re-runs ONLY the failed/partial findings	PASS	parent 13 fail + 1 partial → cloned 14 (not all 25)
Reuses pre-built suite (no regeneration)	PASS	new run <code>totalTests=14</code> (not regenerated to 25)
Shows "Resolved X of Y" delta	PASS	live demo: 9 of 14 resolved after "fixing" the agent
Errored/missing re-tests not mislabeled	PASS	review fix — <code>unevaluated</code> bucket; all-clear gated on it
Frontend button + result page render	PASS	screenshot-verified; present in served bundle

UAT verdict: SIGNED OFF.

5 · Defect density & time to resolve

- **New/changed code this cycle:** ~600 LOC (re-test feature + tests + in-cycle audit-fix work).
- **Defects in new/changed code:** 4 (1 Med, 3 Low) → **density ≈ 6.7 / KLOC**.
- **Average time to resolve:** all 4 resolved **same session (< 1 hr each)** — caught in review/tests before QA hand-off, so **0 escaped**.

Follow-ups added to backlog

- Controller/integration test harness (mock prisma) to unit-cover `reverifyRun`, auth/MFA, webhook fixes.
- Client test setup (vitest + React Testing Library) to cover the re-verify delta logic directly.
- Resolve the 6 deferred audit findings (H-05 first).